

Nombre: _____

Fecha: _____

Taller: Introducción a la Norma ISO 27000

Duración: 1 hora

Objetivo:

El objetivo de este taller es proporcionar a los participantes una comprensión básica de la serie de normas ISO 27000 relacionadas con la gestión de la seguridad de la información. Se explorarán los conceptos clave, la estructura de la norma y cómo aplicarla en un entorno empresarial.

1. ¿Qué es un Sistema de Gestión de Seguridad de la Información (SGSI) según la ISO/IEC 27001?

Objetivo: Comprender el concepto y los beneficios de implementar un SGSI.

- Investigar los componentes de un SGSI.
- Explicar cómo un SGSI puede proteger la confidencialidad, integridad y disponibilidad de la información en una empresa.

2. ¿Cuáles son los principios de la gestión de riesgos de la información bajo la ISO/IEC 27005?

Objetivo: Comprender la importancia de una gestión proactiva de riesgos de la información.

- Definir los pasos clave en la identificación y evaluación de riesgos de seguridad.
- Investigar cómo la ISO/IEC 27005 guía a las organizaciones en la toma de decisiones para mitigar riesgos.

3. ¿Cómo el ciclo PDCA (Planificar, Hacer, Verificar, Actuar) apoya la mejora continua en un SGSI?

Objetivo: Entender cómo el ciclo PDCA asegura la evolución constante del sistema de seguridad.

- Explicar el ciclo PDCA y su aplicación en la seguridad de la información.
 - Investigar ejemplos de cómo las organizaciones aplican este ciclo para mejorar sus controles de seguridad.
4. ¿Qué son los controles del Anexo A de la ISO/IEC 27001 y cómo pueden aplicarse en una empresa?

Objetivo: Explorar los controles específicos que protegen los activos de información

- Investigar la función de los controles del Anexo A.
 - Elegir algunos controles y explicar cómo se aplican en escenarios empresariales.
5. ¿Cuáles son los principales desafíos al implementar ISO 27001 en una organización y cómo superarlos?

Objetivo: Identificar soluciones a problemas reales al implementar un SGSI.

- Investigar barreras comunes como los costos, la resistencia interna y la falta de conocimiento técnico.
 - Proponer estrategias prácticas para superar estos desafíos.
6. Genere una lista de todos los capítulos adicionales a ISO 27001, ISO27002 e ISO 27005 y su objetivo.